

Cisco RV路由器设备模拟仿真

☰ IoT 11个月前 👤 admin

👁 780 💬 4 ☆ 0

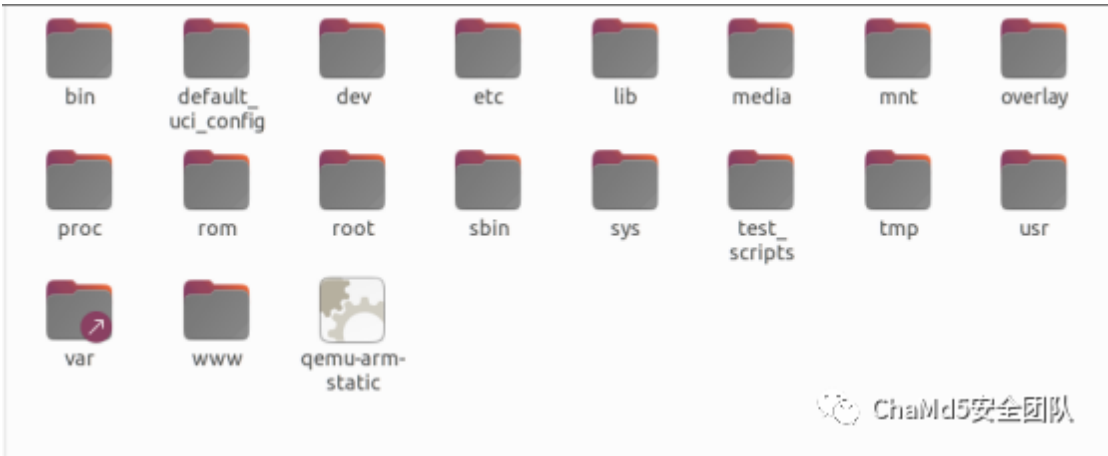
Cisco RV系列路由器是Cisco公司开发的小型家用路由器，但是其相关模拟资料非常有限，因为其具有较多的依赖，于是利用时间，对Cisco RV系列路由器模拟进行了研究。模拟平台为qemu平台，用户级别和系统级别均进行了模拟实现。

一、固件解包：

固件型号：RV34X-v1.0.03.18-2020-06-11-11-55-25-AM.img
解包方式：和传统的.bin固件不相同，通过binwalk解压img文件，会得到7z压缩格式的压缩包，继续对压缩包进行连续的解压，即可得到最后包含openwrt-rootfs.img的文件，利用binwalk解压该文件，即可获得文件系统。根据观察，也可知道该路由器固件基于openwrt开发。
解包命令：

```
binwalk -e openwrt-comcerto2000-hgw-rootfs-ubi_nand.img
```

得到文件系统如下：



二.固件用户级模拟：

我们首先模拟启动路由器终端，在启动终端之前，先赋权以及挂载dev和proc目录。



```
chmod a+x bin/sh
chmod a+x bin/busybox
mount --bind /dev dev
mount --bind /proc proc
sudo chroot . ./qemu-arm-static bin/sh
```

为了分析路由器的启动流程，我们进入etc/init.d文件夹下分析相关启动脚本， init.d目录包含许多系统各种服务的启动和停止脚本，里面的shell脚本能够响应start， stop， restart， reload命令来管理某个具体的应用。我们查看init.d文件夹下的各个脚本文件：

我们发现init.d文件夹下有nginx服务，因此可以推测路由器的web服务框架为nginx框架，因此为了模拟路由器的web服务，我们利用脚本启动nginx服务。

```
cd etc/init.d/
./nginx start
```

发现nginx服务没有正常启动，其中报错信息如下，有多个依赖错误，需要我们依次解决。首先是缺少confd相关服务。

我们利用全局搜索“confd”字符串：

```
grep -r "confd"
```

发现在init.d的confd执行文件中进行了confd服务的启动，因此我们尝试启动confd服务：

```
./confd start
```

但是启动confd时发现错误：

根据错误提示我们知道是ssl相关配置证书出现问题，因此我们继续查询ssl相关配置证书的文件，发现生成默认证书：generate_default_cert脚本。

💬

🐼

☁️ 29°C

📄

🌙

执行该脚本：

```
generate_default_cert
```

执行后发现提示缺少相关的uci文件：

查找uci相关文件，定位到boot文件：

```
./etc/init.d/boot
```

因此我们可以知道整体的模拟流程：

```
chmod -R 777 rootfs
cd rootfs
sudo mount --bind /proc proc
sudo mount --bind /dev dev
chroot . ./qemu-arm-static /bin/sh
/etc/init.d/boot boot
generate_default_cert
/etc/init.d/confd start
/etc/init.d/nginx start
```

当再次启动nginx服务时，发现端口被占用：

怀疑是之前nginx服务关闭时出现问题，相关端口没有完全关闭。因此我们重启nginx服务。

```
./nginx stop
./nginx start
```

现在访问127.0.0.1，即可进入cisco登录界面。

三.固件系统级模拟：

查看架构，得知路由器为ARM小端架构，因此进行系统模拟，系统模拟启用脚本如下：

```
wget https://people.debian.org/~aurel32/qemu/armhf/debian_wheezy_armhf_standard.qcow2
wget https://people.debian.org/~aurel32/qemu/armhf/vmlinuz-3.2.0-4-vexpress
wget https://people.debian.org/~aurel32/qemu/armhf/initrd.img-3.2.0-4-vexpress
sudo apt-get install bridge-utils
sudo brctl addbr Virbr0
sudo ifconfig Virbr0 192.168.153.1/24 up
sudo tuncctl -t tap0
sudo ifconfig tap0 192.168.153.11/24 up
sudo brctl addif Virbr0 tap0
#qemu启动
sudo qemu-system-arm -M vexpress-a9 -kernel vmlinuz-3.2.0-4-vexpress -initrd initrd.img-3.2.0-4-vexpress -
drive if=sd,file=debian_wheezy_armhf_standard.qcow2 -append "root=/dev/mmcblk0p2" -net nic -
net tap,ifname=tap0,script=no,downscript=no -nographic -s
#qemu网卡配置
ifconfig eth0 192.168.153.2/24 up
#上传根目录文件
scp -r rootfs/ root@192.168.153.2:~/
sudo mount --bind /proc proc
sudo mount --bind /dev dev
chroot. /bin/sh
```

之后的配置脚本同用户级模拟，配置完毕后，在虚拟机中访问qemu对应IP即可进入相关的web服务。

四、cve-2021-1414漏洞分析

根据网上的相关资料可知，RV340路由器存在命令注入漏洞。该漏洞位于json-rpc中，当其对snmp相关协议进行处理时，存在命令注入漏洞。我们利用qemu模拟的路由器，进入其web界面，对snmp服务进行相关操作：

发现在qemu模拟起来的nginx服务终端上，可以追踪到其后端的服务文件：jsonrpc.cgi：

利用ida逆向jsonrpc.cgi，定位rpc处理的相关函数：sub_149FC，定位snmp设置，即set_相关函数：

sub_12D84判断请求是否非法，合法即调用sub_13BA0进行处理，跟进sub_13BA0函数，发现其调用jsonrpc_set_config函数进行配置：

jsonrpc_set_config为动态链接库中的函数，我们利用全局搜索定位一下其所在的so文件，位于libjsess.so中。

libjsess.so中提供snmp相关服务函数，我们根据漏洞描述，定位usmUserPrivKey相关函数：



根据逆向可知，v44接收SNMP配置中的usmUserPrivKey字段内容，赋值给v19，v19通过sprintf赋值给v60，系统不做检查，直接利用popen对v60进行执行，造成命令注入。

利用qemu模拟的web服务，更改SNMP相关配置：

利用Burpsuite抓取数据包，将usmUserPrivKey字段修改为要执行的命令，重放攻击即可。

招新小广告

ChaMd5 Venom 招收大佬入群

新成立组IOT+工控+样本分析 长期招新

欢迎联系admin@chamd5.org

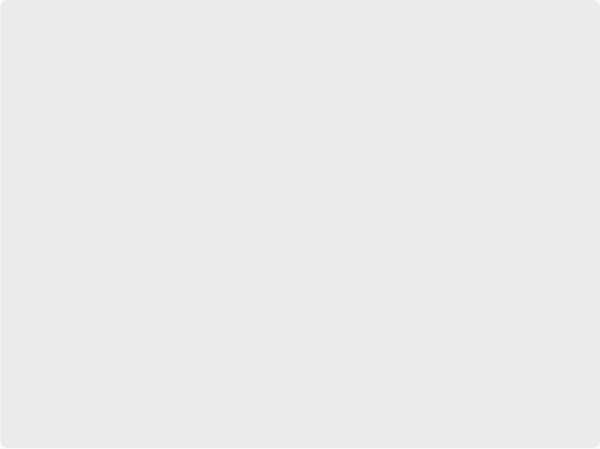
▲▲▲▲

~~~~~

版权声明： [admin](#) 发表于 2021年9月15日 上午12:00。  
转载请注明： [Cisco RV路由器设备模拟仿真 | CTF导航](#)

[上一篇](#)  
[Cisco Cook常用方法与技巧](#)

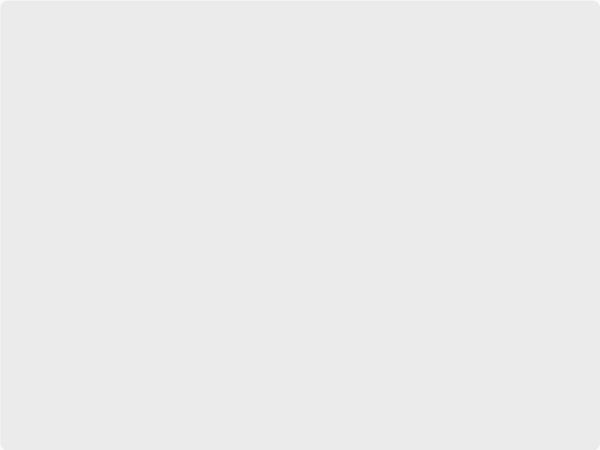
[下一篇](#)  
[【技术分享】家用路由器取证实战？](#)

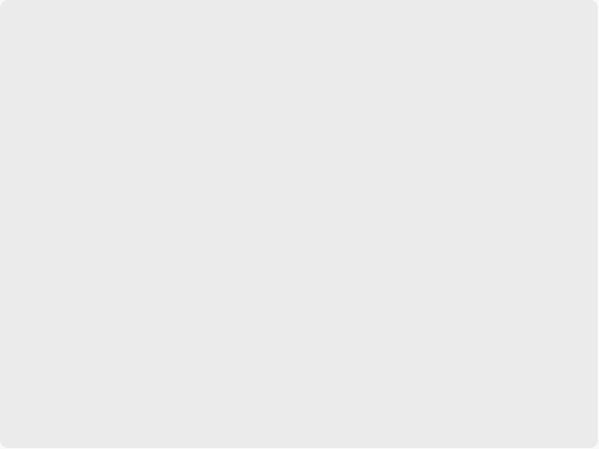


### 2021年物联网设备CVE天梯榜

admin

 262

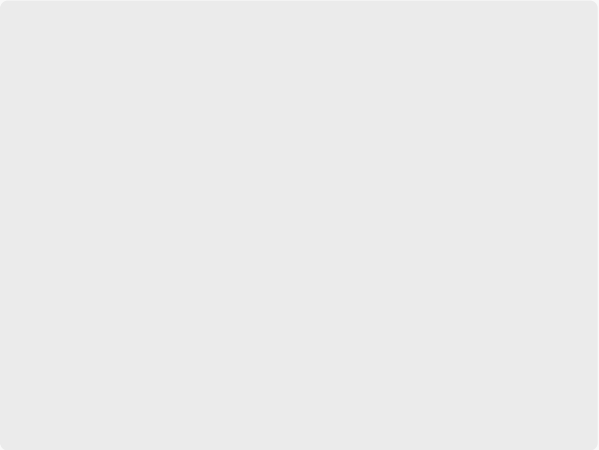


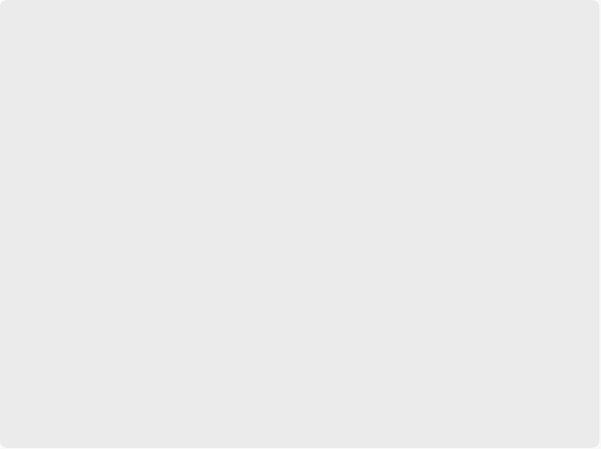


### PULLING MIKROTIK INTO THE LIMELIGHT

admin

 98

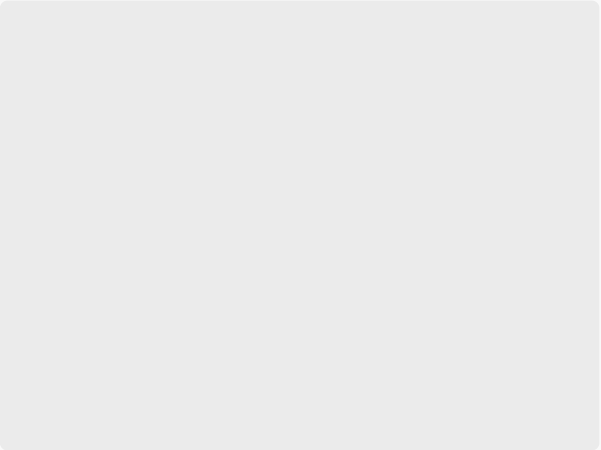


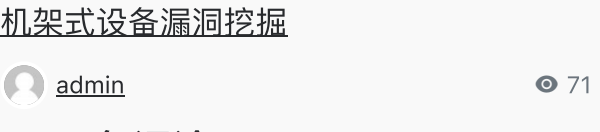


### Advisory: Cisco RV340 Dual WAN Gigabit VPN Router (RCE over LAN).

admin

 257





### 机架式设备漏洞挖掘

admin

 71



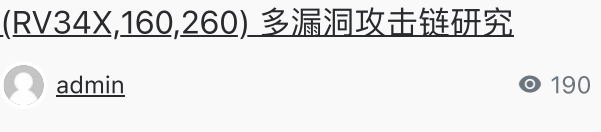


### 由破解电梯卡初识RFID实验

admin

 187

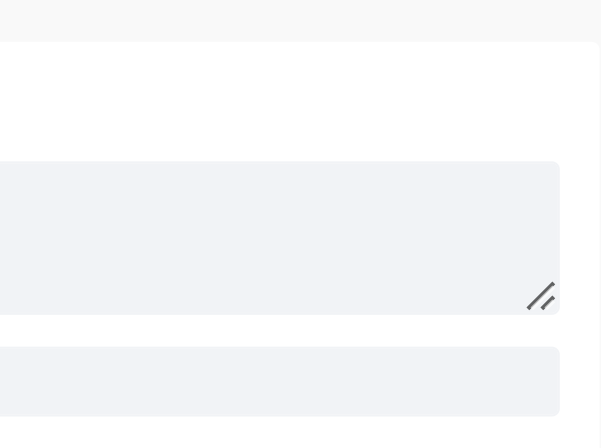




### (RV34X,160,260) 多漏洞攻击链研究

admin

 190



 4 条评论



输入评论内容...

昵称

邮箱

网址

发表评论



Logitte 

一直报错/devmdtblock设备缺失怎么解决?

5个月前

回复



admin 

这个好像不要紧吧，能把http服务起来就行了

4个月前

回复



Ler2sq 

\*\*\* no app loaded. going in full dynamic mode \*\*\*  
\*\*\* uWSGI is running in multiple interpreter mode \*\*\*  
spawned uWSGI master process (pid: 4068)  
spawned uWSGI worker 1 (pid: 4072, cores: 1)  
spawned uWSGI worker 3 (pid: 4073, cores: 1)  
spawned uWSGI worker 4 (pid: 4074, cores: 1)  
/ #  
到此为止nginx就挂了 好像起不来

1个月前



admin 

最好去公众号找下这篇文章，然后留言让作者看一下



29°C







3周前

回复

Copyright © 2022 [CTF导航](#) Designed by [ChaMd5](#)

